

SA-BACKEND-03 · Requisito 5

Respuesta y evidencias · Control de acceso al conjunto de la API

Seven Arena SPA · Área Backend / Infraestructura · Fecha de respuesta: 30 de agosto de 2026 · Responde a: SA-BACKEND-03 v1.0 (29-08-2026), Anexo II a SA-BACKEND-01

PUNTO	MATERIA	ESTADO
5.3.1	Guard global (APP_GUARD) con exclusiones explícitas y documentadas	RESUELTO
5.3.2	Supresión de credentialCode en la respuesta de /athletes	RESUELTO
5.3.3	Protección parcial por módulos (alternativa)	No aplica: se ejecutó 5.3.1 con alcance total
5.4	Verificación de cierre en entorno productivo	VERIFICADO

Resumen. La corrección se desplegó en el entorno productivo el 30 de agosto de 2026 (commit 3ec4b86, rama main). Desde ese momento la totalidad de la API exige autenticación por omisión; los cinco servicios enumerados en 5.4 responden HTTP 401 sin credenciales, y la respuesta autenticada de /athletes no contiene el campo credentialCode ni la credencial de sesión metadata.portalSessionId.

5.3.1 · Control de acceso a nivel de aplicación

Implementación

Se declaró un guard global en src/app.module.ts mediante el proveedor APP_GUARD (src/auth/api-auth.guard.ts). El guard se ejecuta antes que cualquier controlador y rechaza con 401 Autenticación requerida toda petición que no acredite una de las identidades aceptadas. En consecuencia, **los servicios que se incorporen en el futuro quedan protegidos por omisión**: para exponer un endpoint sin autenticación es necesaria una acción explícita (@Public()) que debe llevar su justificación en el código.

IDENTIDAD	CREDENCIAL	QUIÉN LA UTILIZA
Personal del panel	Authorization: Bearer <JWT Supabase>, emitido por POST /auth/login con correo y contraseña	Administración de Seven Arena
Portal · atleta	Sesión única de portal (x-portal-kind / x-portal-user / x-portal-session), obtenida con POST /m/auth/login y POST /m/auth/session/claim	Atletas y usuarios VIP
Portal · conductor	Ídem	Conductores (flota propia o de proveedor)

Portal · staff	Ídem	Personal de proveedor (portal de control de acceso)
----------------	------	--

Una cuenta Supabase vinculada a un conductor (`drivers.user_id`) se resuelve como conductor de portal y no como personal del panel. Adicionalmente, el decorador `@StaffOnly()` restringe al personal del panel los servicios de gestión de usuarios (`/auth/register` , `/auth/users*`), el asistente SoflA, la purga de cuentas y la selección y prueba de notificaciones push; una identidad de portal recibe `403` en ellos.

Exclusiones explícitas (`@Public()`)

Inventario completo de los endpoints que permanecen sin exigir autenticación de plataforma, con su justificación. El inventario se mantiene también en el repositorio (`docs/API_AUTH.md`).

ENDPOINT	JUSTIFICACIÓN
<code>GET /</code>	Health check de la plataforma (Railway). No devuelve datos.
<code>POST /auth/login</code> <code>POST /auth/change-temporary-password</code>	Inicio de sesión del panel. La credencial es la contraseña del usuario.
<code>POST /m/auth/login</code> , <code>/m/auth/recover</code> , <code>/m/auth/session/claim</code> , <code>/m/auth/session/validate</code> , <code>/m/auth/session/release</code> , <code>/m/auth/account/delete</code> , <code>/m/auth/realtime-token</code>	Inicio de sesión y ciclo de vida de la sesión única de los portales. Cada operación valida su propia credencial (código de acceso o identificador de sesión) y no devuelve datos de terceros.
<code>POST /athletes/request-access</code> <code>POST /drivers/request-access</code> <code>POST /access-control/request-access</code>	Recuperación del código de acceso: la respuesta es siempre neutra y el código se envía únicamente al correo registrado del titular.
<code>POST /coupon-partners/auth/login</code> , <code>/coupon-partners/auth/logout</code> , <code>/coupon-partners/me/*</code>	Portal de socios de cupones. Autenticado por su propio guard (<code>PartnerAuthGuard</code> , token de socio <code>X-Partner-Token</code>) y acotado a los datos del socio.
<code>POST /vehicle-positions</code>	Ingesta GPS del shell nativo (sólo escritura, sin lectura de datos). Régimen transicional documentado en SA-BACKEND-02 (<code>VEHICLE_POSITIONS_INGEST_AUTH=log</code>); pasa a <code>enforce</code> cuando el shell adjunte la sesión del conductor. La lectura del servicio exige autenticación y autorización por participación.

Adecuación de los portales

Los cuatro portales web (usuario, VIP, conductor y control de acceso) resolvían el código de acceso en el navegador a partir del listado completo de participantes, lo que era la causa de que dichos listados debieran permanecer públicos. Se reemplazó ese mecanismo por el inicio de sesión en el servidor (`POST /m/auth/login`): el navegador envía únicamente el código y recibe únicamente su propia identidad; los datos protegidos se solicitan después, ya con sesión.

5.3.2 · Supresión de `credentialCode`

El campo `credentialCode` se eliminó de la representación de los participantes en los listados `GET /athletes` y `GET /drivers`. En el detalle de un participante sólo lo reciben el personal del panel o el propio titular (lo requiere para su credencial digital); cualquier otra identidad recibe la representación reducida.

Se trató con el mismo criterio el campo `metadata.portalSessionId`, listado en 5.2.2: es la credencial de la sesión activa del titular y su exposición permitía suplantar la sesión sin conocer el código de acceso. Un interceptor global (`APP_INTERCEPTOR`, `src/auth/sensitive-fields.interceptor.ts`) elimina `portalSessionId` y `portalSessionAt` de toda respuesta JSON de la API, con independencia del módulo que la produzca.

5.4 · Verificación de cierre

Comprobación sin credenciales

Ejecutada el 30 de agosto de 2026 contra `https://proyect-seven-production.up.railway.app`, exactamente con el bucle indicado en 5.4:

```
/trips          401
/athletes       401
/drivers        401
/support-chats  401
/vehicle-positions 401
```

El health check `GET /` se mantiene en `200` por diseño. Captura de la ejecución en el **Anexo A**.

Comprobación autenticada de `/athletes`

Con una sesión del panel iniciada mediante `POST /auth/login`, se solicitó `GET /athletes` y se contaron las ocurrencias de los campos sensibles en el cuerpo completo de la respuesta:

```
Login OK, token de 942 caracteres
--- inicio de la respuesta ---
[{"id":"ecf630e7-...", "eventId":"...", "fullName":"...", "email":"..." ...
--- credentialCode en la respuesta: 0
--- portalSessionId en la respuesta: 0
```

El servicio entrega el listado a la identidad autorizada y la respuesta no contiene `credentialCode` ni `portalSessionId`. Captura en el **Anexo B**.

Hallazgos adicionales durante la ejecución

- **Registro de usuarios del panel sin autenticación.** `POST /auth/register` y `/auth/users*` eran alcanzables sin credenciales, lo que permitía crear cuentas administrativas. Quedaron bajo `@StaffOnly()`. Se informa por transparencia; no consta uso indebido.
- **Código de acceso derivado del identificador.** El código de acceso de los portales se deriva del identificador interno del titular. Con la API cerrada el riesgo anónimo desaparece, pero un usuario

autenticado que conozca el identificador de otro podría iniciar sesión en su nombre. Se planifica su reemplazo por un código aleatorio e independiente del identificador (afecta al inicio de sesión de la aplicación, a los correos de recuperación y a los cuatro portales) como iteración inmediatamente posterior al cierre del presente requisito.

Impacto operativo. El cambio no afecta a la aplicación publicada (el shell nativo carga los portales web y sólo consume directamente la ingesta GPS, que conserva su régimen transicional). La aplicación Expo interna del repositorio (`mobile/`), sin uso en producción, recibe `401` en la totalidad de sus llamadas.

Anexos

- **Anexo A** — Captura del bucle de verificación 5.4 (cinco servicios → `401`).
- **Anexo B** — Captura de la comprobación autenticada de `/athletes` (`credentialCode` = 0, `portalSessionId` = 0).
- **Referencia en el repositorio** — commit `3ec4b86` (`main` y `develop`); `docs/API_AUTH.md` ; `src/auth/api-auth.guard.ts` , `src/auth/public.decorator.ts` , `src/auth/staff-only.decorator.ts` , `src/auth/sensitive-fields.interceptor.ts` .